情報処理安全確保支援士試験　科目A-2　中分類25 情報セキュリティ対策　#09

インシデント対応と脅威インテリジェンス

知る（インテリジェンス）、備える（計画・訓練）、動く（対応・報告）、戻す（復旧）

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、NIST SP 800-61、JPCERT/CC、FIRST、OASIS、個人情報保護委員会、IPA 内部不正防止ガイドラインなど）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類25 小分類1〜3（組織的・人的・物理的管理策に関する技術・手法）

1 脅威インテリジェンス
OSINT・IoC・痛みのピラミッド・STIX・TAXII・TLP・脅威ハンティング・テイクダウン

2 インシデント対応と事業継続
ハンドリング・4つの段階・トリアージ・IRP・CSIRT マテリアル・報告と通知・公表・保険・事後レビュー、RTO・RPO・代替サイト

3 人的・物理的な対策
内部不正防止ガイドライン・訓練（標的型メール・レッドチーム・机上）・UEBA・クリアランス・ゾーニング・アンチパスバック・MDM

過去の午前 II での出方

テーマ	出た回
IoC に該当するもの	R7春
UEBA の機能	R7秋
STIX/TAXII（ATT&CK の誤りの選択肢）	R6秋

午前 II では新しい言葉が**1問ずつ**出始めた段階。科目B では**インシデント対応の判断**（隔離・報告・復旧の順番）が中心になる。

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類25 小分類1〜3／IPA 午前 II 令和7年度春期 問13・令和7年度秋期 問14・令和6年度秋期 問3

第1章

脅威インテリジェンス

集めた情報を、使える知見に変えて、決まった形で共有する。

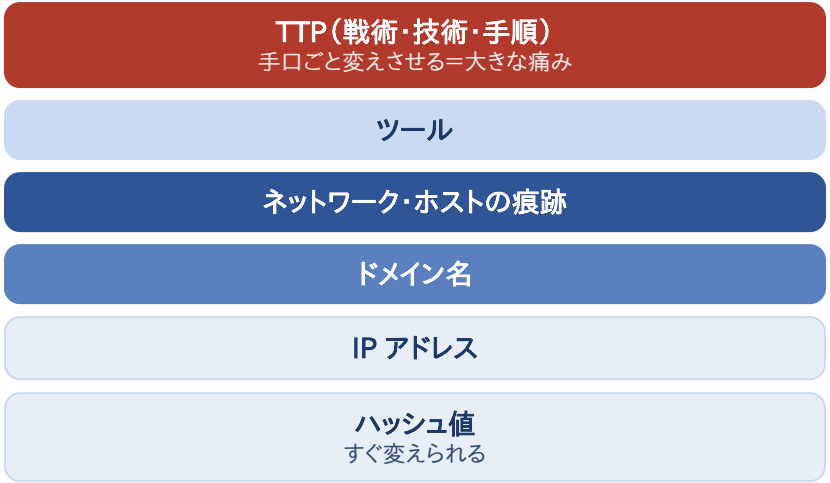
IoC と痛みのピラミッド

R7春 問13：IoC に該当するのは

選択肢	IoC か
JVN の脆弱性情報	いいえ（攻撃の可能性）
認証局の失効リスト	いいえ（CRL）
機器のログの C&C との通信履歴	**はい（侵害の痕跡）**
FW のフィルタリングルール	いいえ（防御の設定）

> IoC＝**侵害された痕跡**。ハッシュ値・C2 の IP/ドメイン・不審なレジストリ・通信のパターン。

痛みのピラミッド（上ほど攻撃者が変えにくい）



出典：IPA 午前 II 令和7年度春期 問13／David J. Bianco「The Pyramid of Pain」（2013）

STIX・TAXII・TLP：書き方・運び方・広げ方

STIX
何を書くか（形式・JSON）
→
TAXII
どう運ぶか（HTTPS の API）
→
受け手
SIEM・SOAR に取り込む

```
{ "type": "indicator",
  "pattern": "[ipv4-addr:value = '198.51.100.7']",
  "pattern_type": "stix",
  "valid_from": "2026-11-01T00:00:00Z" }
```

STIX のオブジェクト：攻撃者・キャンペーン・攻撃パターン・マルウェア・指標（indicator）・対策 など。

TLP 2.0	共有してよい範囲
RED	その場の受け手本人だけ
AMBER+STRICT	受け手の**組織の中だけ**
AMBER	組織の中と、必要な顧客まで
GREEN	コミュニティの中まで（公開しない）
CLEAR	制限なし（旧 WHITE）

出典：OASIS「STIX Version 2.1」「TAXII Version 2.1」／FIRST「Traffic Light Protocol (TLP) Version 2.0」（2022）。STIX の例は Claude が作った（アドレスは文書用）

OSINT・脅威ハンティング・テイクダウン

OSINT

報道・SNS・公開レポート・CT ログ・WHOIS。防御側は**自組織の漏えいや攻撃予告**を探す。攻撃者は偵察に使う（#02）。

脅威ハンティング

潜んでいる前提で、仮説を立てて能動的に探す。アラートを待つ通常の監視と違う。見つけた手口は検知ルールへ。

テイクダウン

フィッシングサイト・配布サイト・C2 の停止を、ホスティング事業者や登録事業者に依頼。**証拠を残してから**。

インテリジェンスの種類	読み手	例
戦略的	経営層	業界をねらう攻撃の傾向、地政学的なリスク
戦術的	防御の設計者	攻撃者の TTP（ATT&CK で表す）
運用的・技術的	SOC・CSIRT	IoC（ハッシュ値・IP・ドメイン）

出典：IPA「支援士試験 シラバス（案）」用語例「OSINT」「脅威ハンティング」「テイクダウン」。種類の整理は一般的な分け方を Claude がまとめた

第2章

インシデント対応と事業継続

封じ込めてから根絶、根絶してから復旧。

インシデント対応の4つの段階（SP 800-61 Rev.2）

準備
体制・IRP・連絡先・ツール・訓練

→

検知・分析
兆候の発見・トリアージ・範囲の特定・記録

→

封じ込め・根絶・復旧
隔離 → 原因除去 → 戻して監視

→

事後対応
事後レビュー・再発防止

よくある誤り	正しくは
感染 PC の電源をすぐ切る	ネットワークから切り離し、**電源は入れたまま**（メモリの証拠）
原因を除く前に復旧する	根絶してから。でないと再侵入される
確かめてから報告する	**まず報告**。記録は最初から
担当者の責任を追及する	仕組みの改善に目を向ける

トリアージ：インシデントか、範囲内か、影響と緊急度は → 優先順位。

2025年の **Rev.3** は CSF 2.0 の6つの機能（統治・識別・防御・検知・対応・復旧）に合わせて組み直した。Rev.2 の4段階も引き続き基本。

出典：NIST SP 800-61 Rev.2 Figure 3-1・Rev.3（2025）／JPCERT/CC「インシデントハンドリングマニュアル」

報告・通知・公表：個人データの漏えいのとき

個人情報保護委員会への報告と本人通知が義務になる事態

①	要配慮個人情報（病歴など）の漏えい
②	財産的被害のおそれ（カード番号など）
③	**不正の目的**によるおそれ（不正アクセスなど）
④	1,000人を超える漏えい

それぞれ「おそれ」を含む。③は人数に関係なく対象。

報告の2段階

速報
知ってから速やかに（おおむね3〜5日以内）

→

確報
30日以内（③は60日以内）

ほかの届出・対応
警察（被害の相談）、IPA（届出制度）、JPCERT/CC、監督官庁
公表の判断と広報、問い合わせ窓口、偽のお詫びメールへの注意
サイバー保険の連絡（調査会社・弁護士の紹介）

出典：個人情報の保護に関する法律施行規則 第7条・第8条／個人情報保護委員会「ガイドライン（通則編）」3-5／IPA「支援士試験 シラバス（案）」用語例

RTO・RPO と代替サイト

時間の軸で見る



例：「4時間以内に再開、失ってよいのは直近15分」→ RTO＝4時間、RPO＝15分。

RPO を0に近づけるにはリアルタイムの複製、RTO を短くするにはホットサイトや待機系。**どちらも費用が上がる。**

代替サイト	用意しているもの	再開	費用
ホット	同じ機器とデータを稼働させておく	**すぐ**	**高**
ウォーム	機器はあるが、データの復元・設定が必要	**数時間〜数日**	**中**
コールド	場所・電源・回線だけ	**数日〜数週間**	**低**

出典：IPA「支援士試験 シラバス（案）」用語例「復旧目標（RTO, RPO）に基づく復旧設計, 代替サイト（ホットサイト, コールドサイト）」

ランサムウェアに耐えるバックアップ

3-2-1 ルール

3	2	1
3つのコピー	2種類の媒体	1つは離れた場所

加えて、**オフライン**（つながっていない）か**イミュータブル**（一定期間書き換え・削除できない）の保管を1つ。

やりがちな運用	何が起きるか
同じネットワークの共有フォルダに上書き	**本番と一緒に暗号化される**
ドメイン管理者で消せる	**乗っ取られた管理者に消される**
取るだけで戻したことがない	**いざというとき戻せない・RTO を超える**

復旧手順の検証を定期的に。復元の時間を測り、RTO に収まるか確かめる。

出典：IPA「支援士試験 シラバス（案）」用語例「バックアップからの復旧手順の検証」。3-2-1 ルールは広く使われる目安

第3章

人的・物理的な対策

人の不正と過ち、建物と端末を守る。

内部不正を防ぐ5つの基本原則と訓練

基本原則	対策の例
犯行を難しくする	アクセス権の最小化、USB の制限
捕まるリスクを高める	ログの監視と**その周知**、UEBA
犯行の見返りを減らす	重要情報の暗号化、DRM
犯行の誘因を減らす	公平な評価、職場環境の改善
犯罪の弁明をさせない	ルールの周知、誓約書・秘密保持契約

訓練	中身
標的型メール訓練	疑似メールで開封率・**報告率**を測る
レッドチーム演習	攻撃者役が**目標の達成**を試み、検知・対応力を評価
机上演習	シナリオを**話し合い**、判断と手順を確かめる

R7秋 問14 UEBA:「利用者や機器の**異常な振る舞い**を検知」。生体認証・アクセス制御・USB 暗号化は違う。

セキュリティクリアランス:重要経済安保情報保護活用法（2024年成立・2025年施行）で、民間の人も適性評価の対象に。

出典：IPA「組織における内部不正防止ガイドライン 第5版」／IPA 午前 II 令和7年度秋期 問14／重要経済安保情報の保護及び活用に関する法律

物理的な対策:ゾーニングと入退管理、モバイル機器

セキュリティゾーニング

一般
受付・会議室
→
執務
社員証
→
セキュリティ
サーバ室・生体認証

共連れ対策	しくみ
アンチパスバック	入室記録がないと退室できない(逆も)
サークル型ゲート	1人ずつしか通れない
インターロック	2つの扉が同時に開かない

MDM でできること

- パスコード・暗号化の設定を強制
- 入れてよいアプリを制限
- **紛失時の遠隔ロック・遠隔消去(リモートワイプ)**
- OS の版や設定の状態を把握

MAM(業務アプリとデータだけ管理)、BYOD(私物端末の業務利用)。

サポートユーティリティ(電源・空調・給水)の**保守**も物理的対策。

出典:IPA「支援士試験 シラバス(案)」中分類25 小分類3 用語例

まとめ：本番での問われ方

言葉の定義：IoC＝侵害の痕跡、UEBA＝異常なふるまいの検知、STIX＝形式、TAXII＝手順、TLP＝共有範囲。

順番：準備 → 検知・分析 → 封じ込め → 根絶 → 復旧 → 事後対応。

数字：漏えい報告の速報（3〜5日）・確報（30日／不正目的は60日）。RTO は時間、RPO は時点。

科目B（午後）の定番：ログから感染端末を特定 → 隔離の判断 → 影響範囲の調査 → 報告先と期限 → 再発防止。「電源を切る」「確かめてから報告」は誤り。

SIEM・SOAR・EDR などの監視の製品は **#12**、証拠の保全とフォレンジックは **#19**。

出典：IPA 午前 II（このPDFの問題演習）／NIST SP 800-61／個人情報保護委員会ガイドライン